Dynamo Pay

Merchant and Super Admin manual

Prepared for the current multi-merchant release. This manual describes the controls implemented in the /platform workspace and the existing merchant console. It does not treat SMS, Gmail, browser callbacks, or test fixtures as proof of bank settlement.

1. Sign in and workspace security

Open /platform. A merchant owner signs in with the account email and password. A platform operator uses the same screen after the Super Admin creates the account. Sessions use an HttpOnly cookie, CSRF tokens for changes, expiry, revocation, login throttling and TOTP MFA and one-time hashed recovery codes. Platform owners and merchant owners must enroll and confirm MFA before issuing keys, changing settings, inviting staff, or changing financial controls.

If verification delivery is not configured, registration remains EMAIL_PENDING and returns a clear pending response. It does not activate the account or create a receiving account. Configure an HTTPS delivery adapter, send both email and mobile verification, then complete onboarding.

2. Merchant onboarding

The merchant follows Onboarding in this order: register business/contact details, verify email, verify mobile, complete category/address/website/time zone, submit for review, connect an approved provider, and wait for platform approval. The lifecycle is EMAIL_PENDING, PROFILE_INCOMPLETE, UNDER_REVIEW, APPROVED, ACTIVE; SUSPENDED, REJECTED and CLOSED remain visible for history.

The server, not the browser, owns the merchant ID. A merchant can read only its own records. A platform operator can review the directory, request corrections, approve, suspend, inspect activity and assign pricing. Activation requires verified owner contact details and an approved enabled production provider connection.

3. Merchant workspace

The merchant console retains the current Dynamo Pay navigation: Overview, Transactions, Failed payments, Refunds, Split payments, Settlements, UPI Accounts, Business profile, Developer tools and Connections & alerts.

Use UPI Accounts to add receiving VPAs, enable the channel, set amount limits and activate one receiving account. Use Developer tools for the existing merchant API contract and signed webhook URL. Use Connections & alerts for the receiving Android device and explicitly bound Gmail inbox. Observer events are supplementary evidence; a customer clicking Payment done does not prove a credit.

4. Developer keys and API

In /platform, open Developer tools and issue a key with only the scopes the server needs. The secret is shown once after creation and is never stored in browser storage. Revoke or rotate compromised keys. Production requests use the merchant key from a server-side secret manager, an Idempotency-Key, and HTTPS. Typical routes are POST /v1/payments, GET /v1/payments/:id, GET /v1/transactions, POST /v1/refunds, GET /v1/balance, GET /v1/webhooks and POST /v1/webhooks.

The payment response means an order was created. A provider webhook or an owner-reviewed bank credit is required before fulfilment. Merchant systems must verify the raw webhook HMAC, delivery ID, amount,

currency, order ownership and confirmation source, then credit their own wallet once in a database transaction.

5. Super Admin operations

Super Admin opens Merchants to search accounts and review onboarding. Transactions shows persisted sessions and provider orders with merchant ownership, status, amount, timestamps and evidence. Operations shows real callback outcomes, observer heartbeats, cases and incidents. Connections shows provider approval, enablement, amount limits and health tests. Billing manages integer-paise plans, subscriptions, immutable invoice snapshots, external payment references and credit notes.

Every state change requires the appropriate role and is audited. There is no unrestricted force-success action. Provider timeouts remain reconciliation work. Refund and payout uncertainty retains reservations until the real provider result is checked.

Platform roles are Super Admin, Operations, Finance, Support, Security and Auditor. Merchant roles are Owner, Admin, Developer, Finance, Operations, Support and Viewer. Staff invitations are tenant-scoped and cannot grant permissions the inviter does not hold.

6. UPI rules and risk controls

Use Connections & acceptance to create ALLOW, BLOCK or WATCH rules for a merchant, receiving VPA, submitted customer VPA, customer ID or provider. BLOCK wins over ALLOW. WATCH records an audit event and does not approve payment. Rules can expire and every change keeps a revision. These controls apply inside Dynamo Pay; they cannot override bank or NPCI controls.

7. Observers, reconciliation and recovery

Android device heartbeats and Gmail messages are authenticated, deduplicated and stored with original observation time. They do not independently mark a payment successful. If provider confirmation is missing, preserve the original attempt and use authenticated provider inquiry. Conflicting verified credits create reconciliation work. Normal customer checkout has no UTR form and the console no longer exposes the manual bank-review dialog. Exceptional back-office review remains separately authorized and labelled MERCHANT.

Back up PostgreSQL before migrations or deployment. Restore into a separate database and verify counts, ledger balances, private files, keys and webhook delivery state before switching the service. Render Free can sleep and the current trial database has an expiry; durable production hosting is an operational requirement.

8. Where to read next

Use docs/OPERATIONS-MANUAL.md for the detailed current API and observer contract, docs/CONFIGURATION-CREDENTIALS.md for secret names and ownership, docs/PRODUCTION_ACCEPTANCE_REPORT.md for tested evidence and limits, and /developers/openapi.json for the merchant-facing schema.

9. Add and manage merchants

Sign in at /admin and choose Manage merchants, then Add merchant in /platform. The new owner receives a one-time invitation through the configured delivery adapter and chooses their password. If delivery is unconfigured, activation stays pending. The owner must verify contacts and complete onboarding. Open dashboard selects the merchant without impersonation; All merchants returns to the directory. Access & details shows owner activation and verification.

10. Payment and provider limits

Create payment asks only for amount and generates the order reference. Customer name, phone and manual UTR entry are removed from the active creation/checkout UI. Approved providers may still require real customer information from the merchant backend. Cashfree Orders requires a genuine phone; it is not fabricated. A local direct-UPI QR is not a Cashfree dynamic QR. Without approved provider access, automatic provider verification cannot be certified.

The separate 25-module control-center claim is superseded by the actual grouped platform controls and docs/audit/ATTACHED_REQUIREMENTS_MATRIX.md. Render Free hosting, missing provider/KYC credentials and unfinished external acceptance prevent a production-readiness claim.

Private invitation handover when email is unavailable

If email delivery is not configured, Add merchant shows the MFA-authenticated platform owner a one-time invitation link. Copy and share it privately with that merchant owner, preferably using a separate browser profile for testing. The link expires in 24 hours, is consumed once, and is removed from the dialog when closed. It contains no password. Opening it allows the owner to choose their own password. Email/mobile verification and provider activation are still pending; a manually handed-over link does not mark email verified. Access & details can reissue a link only for an owner who has not activated yet.